

Introduction à la Sécurité Informatique et des Réseaux

Labo 1 — Modélisation des Menaces — Trilogie CIA

Scénario : Hôpital National du Wakanda (HNW)

Groupe : 4

Membres du groupe :

- Ibrahima Watt
 - Sekou Diao
 - Bassirou Diao
 - Adama Seck
-

Partie A — Analyse de la Trilogie CIA

Pour chaque situation, nous indiquons si la Confidentialité (C), l'Intégrité (I) ou la Disponibilité (D) est touchée.

1. Un attaquant découvre le mot de passe du Dr Seck et consulte des dossiers patients

- **Confidentialité : Affectée**
Les dossiers médicaux sont consultés par une personne non autorisée.
- **Intégrité : Non affectée**
Les données ne sont pas modifiées.
- **Disponibilité : Non affectée**
Le système continue de fonctionner normalement.

2. Un employé modifie les allergies d'un patient dans SanteNum

- **Confidentialité : Non affectée**
Les informations ne sont pas divulguées.
- **Intégrité : Affectée**
Les données médicales sont modifiées et deviennent incorrectes.
- **Disponibilité : Non affectée**
Le système reste accessible.

3. Un ransomware chiffre la base de données du DME

- **Confidentialité : Affectée**

- Les attaquants peuvent accéder aux données avant le chiffrement.
- **Intégrité : Affectée**
Les fichiers sont modifiés et deviennent illisibles.
- **Disponibilité : Affectée**
Les médecins ne peuvent plus accéder aux dossiers.

4. Le système du laboratoire subit une attaque DDoS et devient indisponible pendant 6 heures

- **Confidentialité : Non affectée**
Aucune donnée n'est volée.
- **Intégrité : Non affectée**
Les données ne changent pas.
- **Disponibilité : Affectée**
Le service est inaccessible pendant plusieurs heures.

5. Un agent transmet des résultats VIH à l'employeur d'un patient

- **Confidentialité : Affectée**
Des informations médicales privées sont révélées sans autorisation.
- **Intégrité : Non affectée**
Les résultats transmis sont corrects.
- **Disponibilité : Non affectée**
Le système continue de fonctionner.

6. Les dosages de médicaments sont modifiés pendant la transmission (attaque MitM)

- **Confidentialité : Affectée**
L'attaquant peut lire les communications.
- **Intégrité : Affectée**
Les dosages sont changés pendant l'envoi.
- **Disponibilité : Non affectée**
Le système reste actif.

7. Un ancien employé utilise encore ses identifiants pour exporter la base de données patients

- **Confidentialité : Affectée**
Des données sensibles sont récupérées par une personne non autorisée.
- **Intégrité : Non affectée**
Les données ne sont pas modifiées.
- **Disponibilité : Non affectée**
Les utilisateurs peuvent toujours accéder au système.

Q1 — Propriété CIA la plus souvent touchée

La propriété la plus souvent violée est la **Confidentialité**.

Dans plusieurs scénarios, des personnes non autorisées accèdent aux données médicales des patients.

Pourquoi ce système est vulnérable dans un hôpital public africain ?

- Les budgets informatiques sont souvent limités.
- Le personnel n'est pas toujours formé à la cybersécurité.
- Les mots de passe faibles sont fréquents.
- Certains systèmes utilisent encore des technologies anciennes.
- Les données médicales ont une grande valeur pour les cybercriminels.

Q2 — Scénario touchant les trois propriétés CIA

Le scénario du **ransomware** affecte les trois éléments de la trilogie CIA.

- **Confidentialité** : les attaquants peuvent accéder aux données.
- **Intégrité** : les fichiers sont modifiés par le chiffrement.
- **Disponibilité** : les dossiers deviennent inaccessibles.

Cette attaque est très dangereuse car elle peut bloquer complètement les activités de l'hôpital et mettre les patients en danger.

Partie B — Faiblesses, Vulnérabilités et Exploits

Définitions

- **Faiblesse** : absence d'une mesure de sécurité.
- **Vulnérabilité** : faille exploitable dans un système.
- **Exploit** : technique utilisée pour profiter d'une vulnérabilité.
- **Attaque** : action menée pour compromettre un système.

Élément	Catégorie	Justification
La page de connexion n'a pas de verrouillage de compte	Faiblesse	Il manque une mesure de sécurité importante.
Un attaquant lance un script de credential stuffing	Attaque	C'est une action malveillante contre le système.
La synchronisation utilise un partage réseau non	Vulnérabilité	Les données peuvent être

Élément	Catégorie	Justification
chiffré		interceptées.
Un mot de passe faible est cassé par force brute	Exploit	L'attaquant profite d'un mot de passe faible.
Le serveur utilise une ancienne version d'Apache avec une CVE connue	Vulnérabilité	La faille est reconnue et documentée.
Un pirate fait une injection SQL pour voler la base de données	Attaque	Il s'agit d'une action offensive contre le système.

Partie C — Phases d'Attaque

1. Reconnaissance

- Les employés publient des informations sur les réseaux sociaux.
- Des appels suspects sont reçus par le service informatique.
- Les attaquants collectent des informations sur les outils utilisés par l'hôpital.

2. Infiltration

- Un e-mail de phishing est envoyé à Fatoumata Diallo.
- Le message contient une pièce jointe malveillante.
- Elle ouvre le fichier sur son ordinateur professionnel.
- Les attaquants obtiennent alors un premier accès au système.

3. Persistance et mouvement latéral

- Certains ordinateurs deviennent plus lents.
- Des connexions inhabituelles apparaissent la nuit.
- Les comptes utilisateurs accèdent à des dossiers inhabituels.
- Les attaquants cherchent à étendre leur accès dans le réseau.

4. Exécution de l'attaque

- Le ransomware chiffre les dossiers patients.
- Une demande de rançon apparaît.
- Les services médicaux sont fortement perturbés.
- Les trois propriétés CIA sont touchées.

5. Dissimulation

- Les attaquants suppriment des journaux d'activité.
- Ils utilisent plusieurs serveurs pour cacher leur origine.
- Ils utilisent de fausses adresses IP pour tromper les enquêteurs.

Q3 — Synthèse et observations

Phases difficiles à distinguer

Les phases de **persistance** et d'**exécution** peuvent être difficiles à séparer.

Les ralentissements du système peuvent être vus comme une préparation de l'attaque ou comme le début de l'impact.

Observation importante

L'utilisation de fausses adresses IP est une technique avancée pour cacher l'origine réelle de l'attaque.

Réflexion de groupe

1. Menace la plus grave

Le ransomware est la menace la plus grave car :

- il bloque les services de l'hôpital ;
- il empêche l'accès aux dossiers médicaux ;
- il peut mettre la vie des patients en danger.

2. Vulnérabilité choisie et contre-mesures

Vulnérabilité

Synchronisation des données via un réseau non chiffré.

Contre-mesure technique

- Utiliser le chiffrement TLS ou un VPN.
- Mettre en place une authentification sécurisée.

Contre-mesure organisationnelle

- Créer des règles de sécurité pour les transferts de données.
- Former le personnel informatique aux bonnes pratiques.

3. Phases difficiles à distinguer

Les phases de persistance et d'exécution sont proches car les signes visibles apparaissent progressivement.

4. Priorité CIA selon le rôle

Point de vue du DSI

Le DSI priorise la **Disponibilité** car l'hôpital doit fonctionner en permanence.

Point de vue du patient

Le patient priorise la **Confidentialité** afin de protéger ses informations médicales personnelles.